

[BUG] Security Vulnerability #7166

✓ Closed#7170

y4ppieflu opened on Oct 26, 2022

...

Vulnerability details

Local file inclusion in the MLFlow server, additional details may be provided upon request.

MLFlow version

Reproduced in 1.26.1 and 1.30.0



harupy on Oct 26, 2022

Member...

[@y4ppieflu](#) Can you provide more details?



y4ppieflu on Oct 26, 2022 · edited by y4ppieflu

Edits ▾Author...

@harupy

Sure, the vulnerability allows to read arbitrary files on the server where mlflow is running via the artifact download handler.



harupy on Oct 26, 2022 · edited by harupy

Edits ▾Member...

[@y4ppieflu](#) Thanks for reporting this vulnerability. I was able to reproduce it.



y4ppieflu on Oct 26, 2022

Author...

Thanks [@harupy](#)

I am hiding the above details for now.



harupy on Oct 26, 2022

Member...

Thank you!

 **harupy** mentioned this [on Oct 26, 2022](#)

 [Validate path parameter is safe #7170](#)

 **github-actions** added **has-closing-pr** [on Oct 26, 2022](#)

 **SkiFast1** mentioned this [on Oct 26, 2022](#)

 [\[BUG\] Security Vulnerability #7169](#)

 y4ppieflu on Oct 27, 2022

Author ...

BTW — shall this follow the process described in the [Security Policy](#) and have an associated [Github Security Advisory](#)?

  **harupy** closed this as [completed](#) in [#7170](#) [on Oct 28, 2022](#)

 y4ppieflu on Oct 28, 2022

Author ...

BTW — shall this follow the process described in the [Security Policy](#) and have an associated [Github Security Advisory](#)?

[@harupy](#) hi, what about my comment above?

 y4ppieflu on Nov 1, 2022

Author ...

Hi [@harupy](#)
kind reminder :)

 y4ppieflu on May 10, 2023

Author ...

CVE record for this issue is now published ([CVE-2023-30172](#))

MLflow v2.0.1 fixes the vulnerability.

 noren95 on May 11, 2023

...

Does 2.0.1? I see that it was merged into 2.0.0 as well. Can you please confirm?

Assignees

No one assigned

Labels

has-closing-pr

Type

No type

Projects

No projects

Milestone

No milestone

Relationships

None yet

Development

 Code with agent mode

▼

 **Validate `path` parameter is safe**
mlflow/mlflow

Participants

